Security & AI Governance

ZECPATH AI | Day 55

ZECPATH AI supports recruitment by processing resumes, screening answers, interview information, scores, and recommendations. The design below sets the safeguards needed to keep that processing job-related, reviewable, and controlled.

1. AI compliance design

Core principles

Principle	Required practice
Purpose and minimization	Use candidate data only for disclosed recruitment purposes; collect and retain only what is needed.
Consent and choice	Check purpose-specific consent before processing. Record withdrawals and stop later processing.
Fairness	Keep protected attributes out of scoring inputs. Use governed group data only for fairness monitoring.
Transparency	Provide job-related reasons, known limits, and notice that AI contributed to an assessment.
Human oversight	A qualified recruiter reviews evidence and makes the hiring decision. AI output is not the sole basis.
Accountability	Record policy versions, scores, decisions, and review outcomes without copying raw candidate content into logs.

Processing flow

Candidate submission -> resolve identity and consent -> process and mask protected fields -> score and explain -> monitor fairness and record audit events -> recruiter review -> human hiring decision.

Missing or withdrawn consent: stop processing. Evaluate retention separately and apply deletion, retention, or a documented legal hold.

Project controls and limits

- The fairness masker removes configured protected fields from a scoring copy. It does not remove protected information embedded in free text or rule out proxy discrimination.
- The bias evaluator reports group score and selection indicators when governed audit data is supplied. The 0.80 disparate-impact and 0.10 score-gap thresholds are review triggers, not proof of fairness or automatic scoring rules.
- The consent manager records grants and withdrawals in memory. The resume-ranking entry point checks resume-processing and AI-screening consent only when its caller supplies the manager and candidate mapping; other processing stages are not yet gated.

2. Security framework

Identity and access

The repository has a default-deny, role-based policy with candidate assignment scopes. It describes candidate, recruiter, interviewer, compliance auditor, consent service, retention worker, AI processing service, and security administrator roles. The policy does not authenticate users, and current report writers do not enforce these checks. A trusted identity service and authorization at every data-service boundary are still required.

Audit logging

The JSONL logger records UTC score and decision events, including scores, thresholds, reasons, risk factors, and review status. Logs are useful evidence but are not tamper-proof. The final recommendation generator contains a decision-logging call without an initialized logger, so that path must be wired and verified before relying on its events. Restrict log access and keep raw resumes and transcripts out of log entries.

Storage and key management

Current report writers save readable JSON or Markdown, and no encryption-at-rest layer is in use. The documented design proposes AES-256-GCM encryption, unique nonces, authenticated metadata, opaque filenames, and keys managed separately from ciphertext. Production use requires managed keys, rotation, protected backups, and tested recovery. Encryption protects stored data; authorization controls who may request decryption.

Retention schedule

Record type	Period	Configured action
Resume / candidate profile	365 days	Delete
Interview recording	90 days	Delete
Transcript	180 days	Delete
AI evaluation	365 days	Delete
Consent record	365 days	Retain
Audit record	730 days	Retain

The retention manager calculates expiry and supports legal holds, but it does not delete files or database records. Define what 'retain' means after the listed period and include backups and exports in deletion workflows.

Operational baseline

- Use TLS for network transfers and restrict storage with operating-system or cloud access controls.
- Keep secrets out of source control; separate key backups from data backups.
- Review role assignments and operator access; log denied access and policy changes.
- Test key rotation, backup restoration, access denial, and retention deletion. Maintain an incident response process for exposed keys or candidate data.

3. Governance

Accountability

Owner	Responsibility
Hiring process	Set permitted purposes, recruiter roles, and human decision steps.
Recruiter / reviewer	Review job-related evidence, record overrides, and handle candidate review requests.
AI / model	Track model and configuration versions; review performance, limits, and fairness indicators.
Security	Manage authentication, assignments, keys, incidents, and recovery.
Privacy / compliance	Approve consent language, retention periods, legal holds, and data-rights procedures.

Model and policy changes

For every model, scoring, threshold, or data-flow change: (1) record the reason, owner, and version; (2) review job relevance, data use, consent, protected-field handling, and limitations; (3) evaluate accuracy and selection patterns, including fairness indicators on governed data; (4) obtain hiring, AI, security, and privacy review; and (5) monitor the release and keep rollback information.

Monitoring

- Review score distributions, selection rates, fairness indicators, human overrides, and reviewer disagreement.
- Track consent denials and withdrawals, unauthorized processing attempts, access grants and denials, and audit-log completeness.
- Review overdue records, failed deletion jobs, legal holds, backup retention, key rotation, recovery tests, and incidents.

Current release status

Control	Current state	Before production
Consent	In-memory records; limited resume-ranking gate.	Persist consent and gate every processing stage.
Access	Role policy exists; no authentication or writer enforcement.	Add verified identity and service-boundary checks.
Storage	Reports are plaintext; encryption is a design only.	Implement encryption, managed keys, migration, and recovery.
Retention	Expiry and holds are modeled; deletion is not executed.	Connect deletion and resolve retain periods.
Audit	JSONL logger exists; final decision logger is unwired.	Wire, verify, restrict, and protect audit events.

Release gate: Do not use this prototype to store real candidate reports or transcripts in production until persistent consent, authentication and access enforcement, encryption, verified decision logging, and actual retention deletion are implemented and reviewed.